

Vibe Coding 学习系列 · CC-10

综合实战完整指南

企业级最佳实践：规范、CI/CD、安全与性能

根据 AI-Coding-Guide-Zh 教程整理

为什么需要团队规范

- 团队超过 5 人，没有统一规范就是灾难开始
- 有人 CLAUDE.md 写 500 行，有人完全没有
- AI 生成的代码风格与团队标准不一致
- 敏感 API 密钥可能被意外提交到仓库
- 不同项目的 MCP 配置会互相冲突

项目目录职责

目录	职责	入库策略
.claude/	命令、钩子、技能配置	必须入库
docs/ai-context/	给 AI 看的项目说明书	建议入库
.github/workflows/	CI/CD 工作流	必须入库
settings.local.json	个人本地覆盖	禁止入库

CLAUDE.md 三层配置

- 全局配置 ~/.claude/CLAUDE.md 适用所有项目
- 项目配置在项目根目录，团队共享并入库
- 子目录配置管模块级特殊规则
- 优先级从低到高：全局、项目、子目录
- 用统一模板写概览、规范、安全、测试、Git

AI 辅助代码审查流程

1

提交 PR

开发者提交代码合并请求

2

自动审查

CI 触发 Claude 审查质量、安全、性能等维度

3

评论反馈

审查结果自动添加到 PR

4

人工复核

审查员复核后合并或请求修改

CI/CD 集成能力

官方 Action

anthropics/claude-code-action

自动代码审查

在 PR 上自动运行 Claude 审查

安全扫描

检查硬编码密钥、注入漏洞等问题

文档生成

push 到 main 时生成 API 文档

权限系统三级模型

- Allow：低风险且频繁的操作直接执行
- Ask：有一定风险的操作执行前需确认
- Deny：高风险操作完全禁止执行
- 未列入 allow 或 deny 的默认需要确认
- deny 支持通配符，可精确拦截危险操作

权限配置示例

类别	示例	效果
允许	Bash(npm test *)	允许运行测试
允许	Read 、 Glob 、 Grep	读取和搜索直接放行
拒绝	Bash(rm -rf /)	禁止删除根目录
拒绝	Read(./ .env)	禁止读取环境变量文件

Sandbox 沙箱配置

- 用 `/sandbox` 启用 OS 级隔离
- `allowWrite` 指定可写路径, 如 `/tmp`、`./src`
- `allowRead` 指定允许读取的路径
- `denyRead` 明确禁止读取, 优先级最高
- 把 `.env` 和密钥文件放进 `denyRead`

审计与合规

审计日志

用 Hooks 记录工具调用和文件访问

日志格式

JSONL 记录时间、工具、结果

GDPR

数据最小化、访问权、删除权

访问控制

密钥轮换、最小权限、日志防篡改

上下文与成本优化

- 精简 CLAUDE.md，避免长篇大论
- 用文件引用代替内联大段内容
- 分层配置：根目录、src、tests、docs
- 对话过长用 /clear 清理或新建会话
- 批量处理任务，避免逐个文件重复调用

成本优化策略

任务类型	推荐选择	原因
简单代码生成	当前可用的低成本模型	成本低，速度快
代码审查	当前可用的平衡模型	兼顾质量和成本
架构设计	当前可用的高能力模型	复杂推理能力更强

“

一句话记住综合实战

规范统一、权限收紧、成本可控，才能把 AI 用进团队

从个人工具到团队基础设施

用四周搭建企业级 Claude Code 环境